Báo cáo Tuần 2

I. Worklog

Nguyễn Xuân Nhật (MSSV: 24110293) Thời gian: 9h

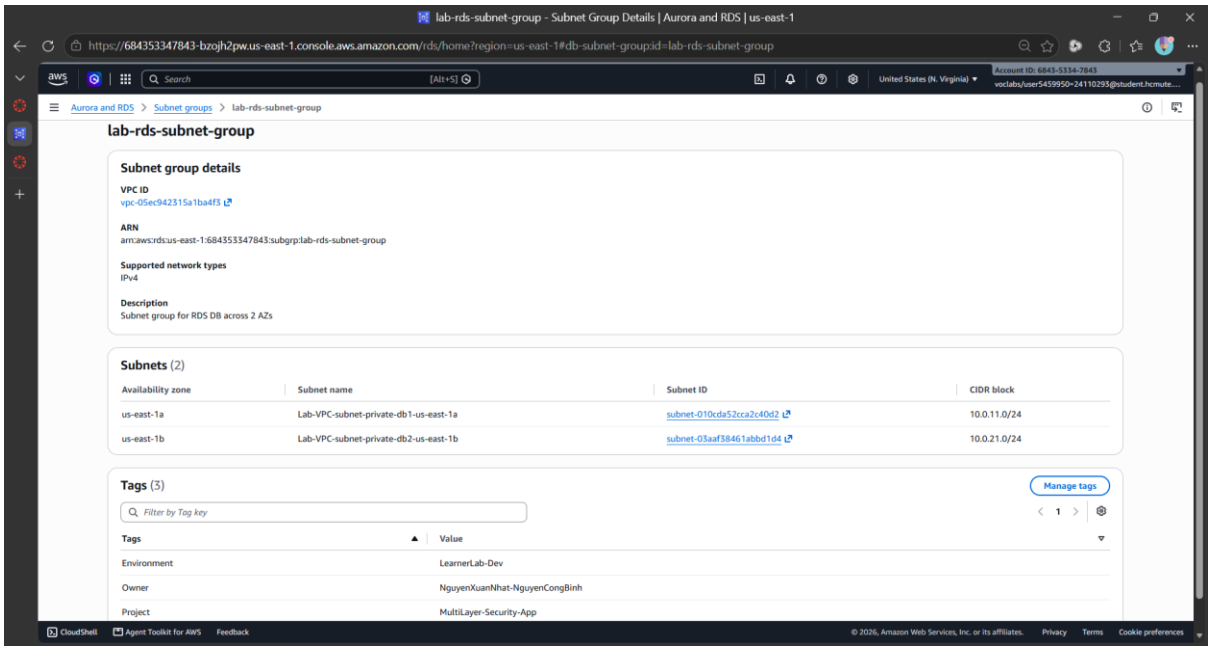
- Khởi tạo Database RDS MySQL. (2 giờ)
- Cấu hình Target Group & Application Load Balancer (ALB). (3 giờ)
- Kiểm thử định tuyến ALB và cách ly mạng Security Group. (4 giờ)

Nguyễn Công Bình (MSSV: 24110168) Thời gian: 9h

- Lưu trữ & quản lý mật khẩu trên Secrets Manager. (3 giờ)
- Dựng máy ảo EC2 Web Server, gắn LabInstanceProfile. (3 giờ)
- Lập trình ứng dụng Web (Flask/Python) lấy secret động và kiểm thử kết nối DB. (3 giờ)

II. Triển khai các chức năng lõi trên AWS

1. Tạo DB Subnet Group



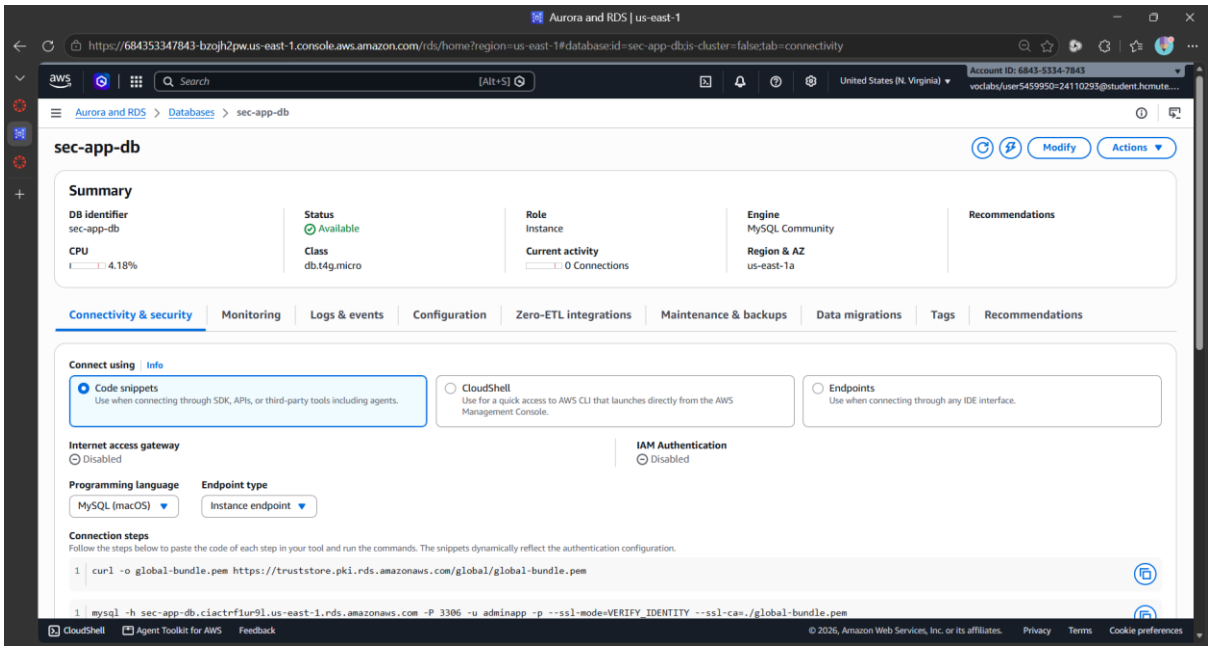
Ảnh 1.1: DB Subnet Group

- **DB Subnet Group:** Báo cho dịch vụ AWS RDS biết cơ sở dữ liệu được phép đặt tại những Subnet nào (ở đây là 2 DB Subnet Private chúng ta đã tạo ở cuối Tuần 1) để đảm bảo tính dự phòng (High Availability) trên 2 Availability Zones.

2. Tạo Amazon RDS MySQL

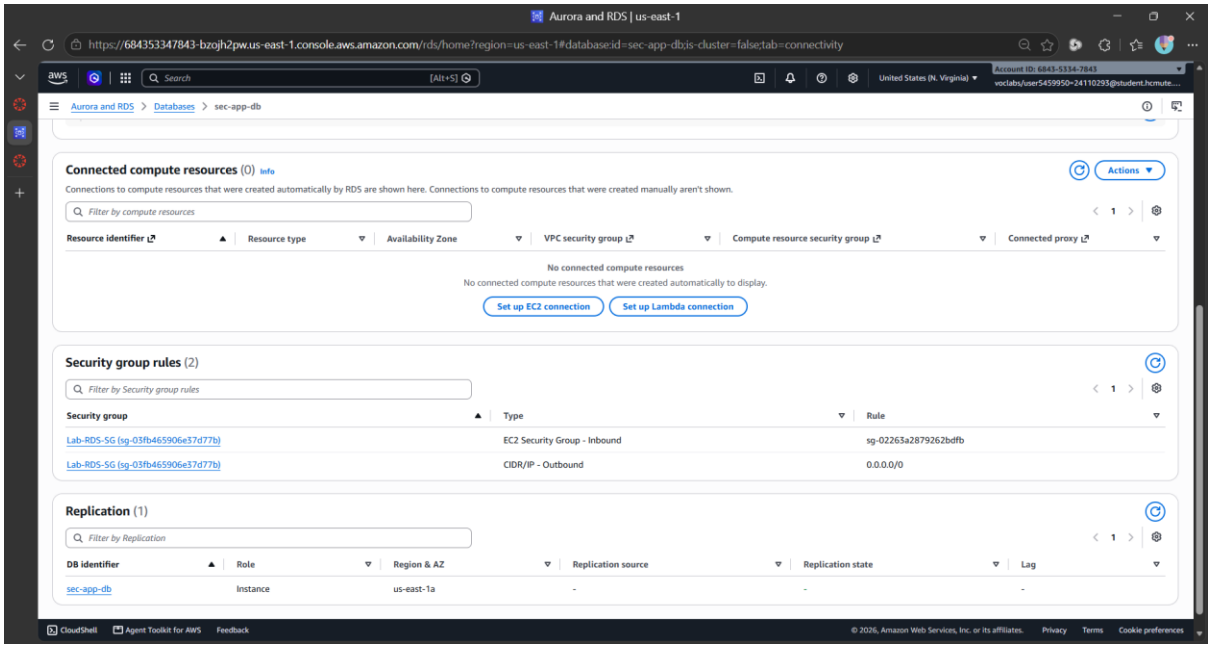
Tổng quan cấu hình và trạng thái hoạt động của cơ sở dữ liệu Amazon RDS MySQL:

Tab Connectivity & security - Code snippets:



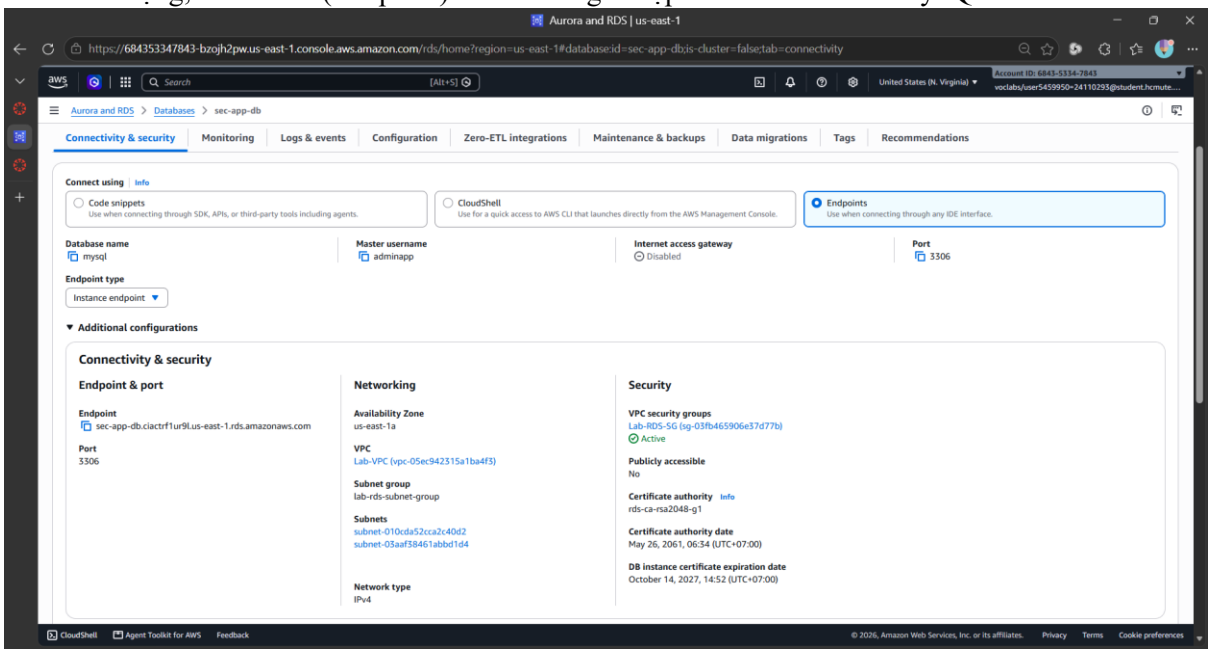
Ảnh 2.1: RDS MySQL Summary

Cấu hình quy tắc an ninh (Security Group Rules) và trạng thái nhân bản của RDS MySQL:



Ảnh 2.2: RDS MySQL Security Group Rules

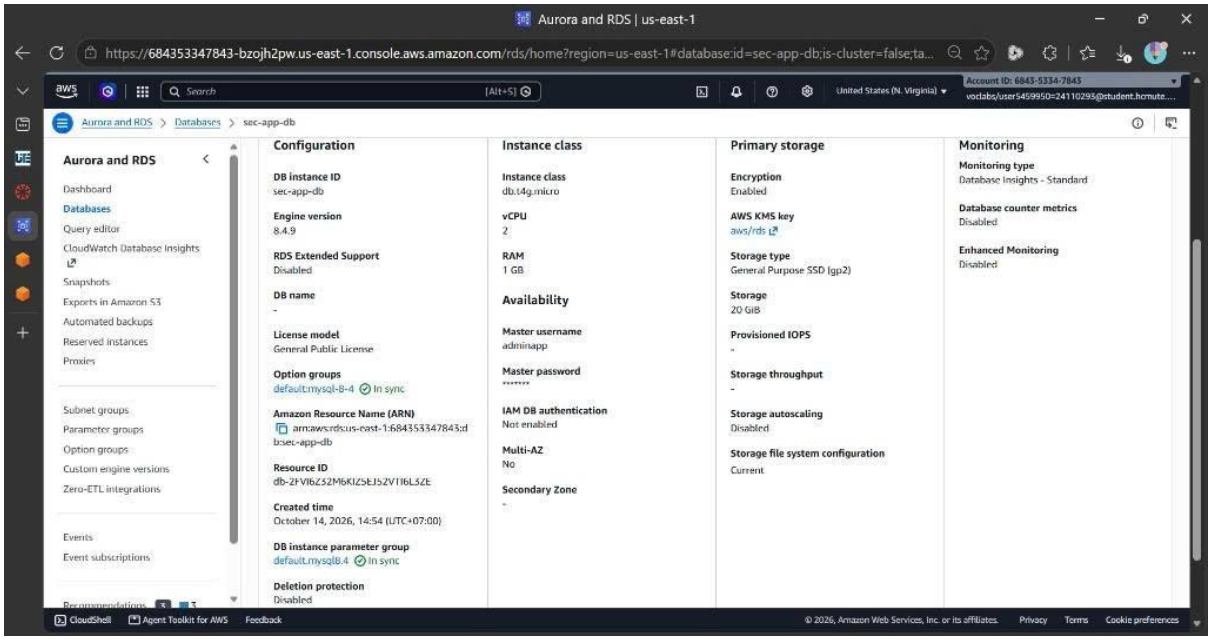
Cấu hình mạng, điểm cuối (Endpoint) và tính năng cô lập an ninh của RDS MySQL:



Ảnh 2.3: RDS MySQL Endpoints

- Nó sẽ được đặt hoàn toàn trong dải mạng nội bộ (Private), tuyệt đối không mở IP Public để chặn đứng mọi cuộc tấn công từ Internet.

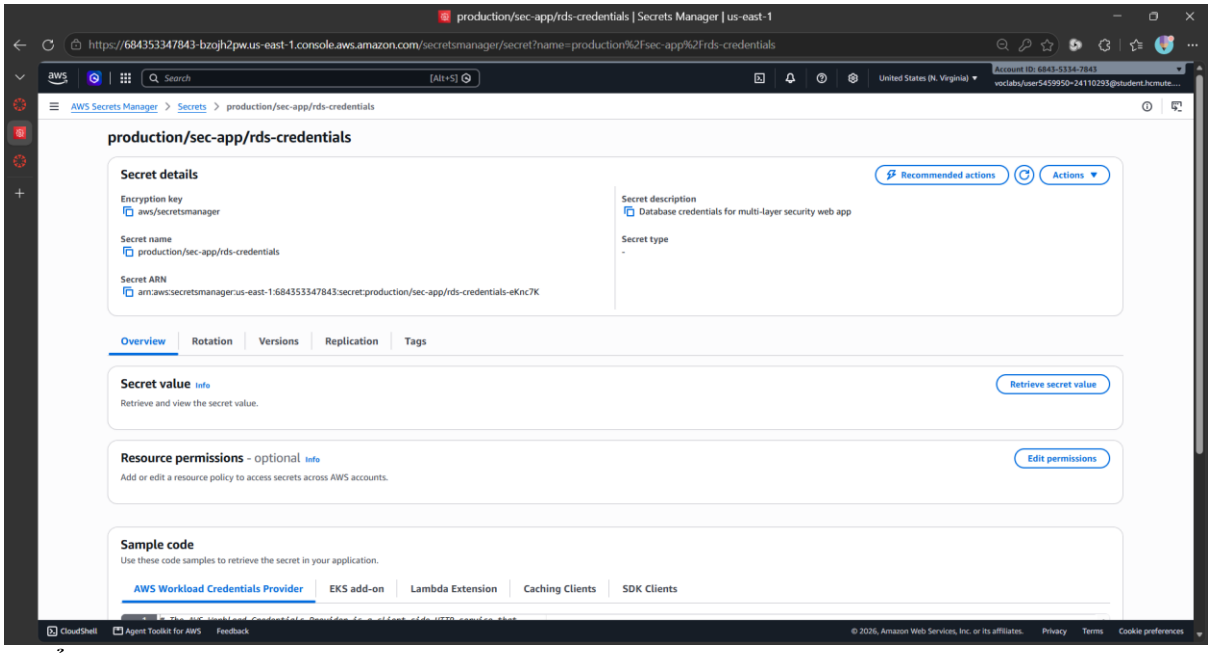
Cấu hình phần cứng và xác thực tính năng mã hóa lưu trữ bằng AWS KMS trên RDS MySQL:



Ảnh 2.4: RDS MySQL Configuration KMS

- Đảm bảo bảo vệ dữ liệu chống lại các nguy cơ truy cập vật lý trái phép vào ổ đĩa hoặc rò rỉ dữ liệu từ các bản sao lưu (Backup/Snapshot), đáp ứng tiêu chuẩn phòng thủ dữ liệu tĩnh (Data-at-Rest Encryption) theo mô hình STRIDE

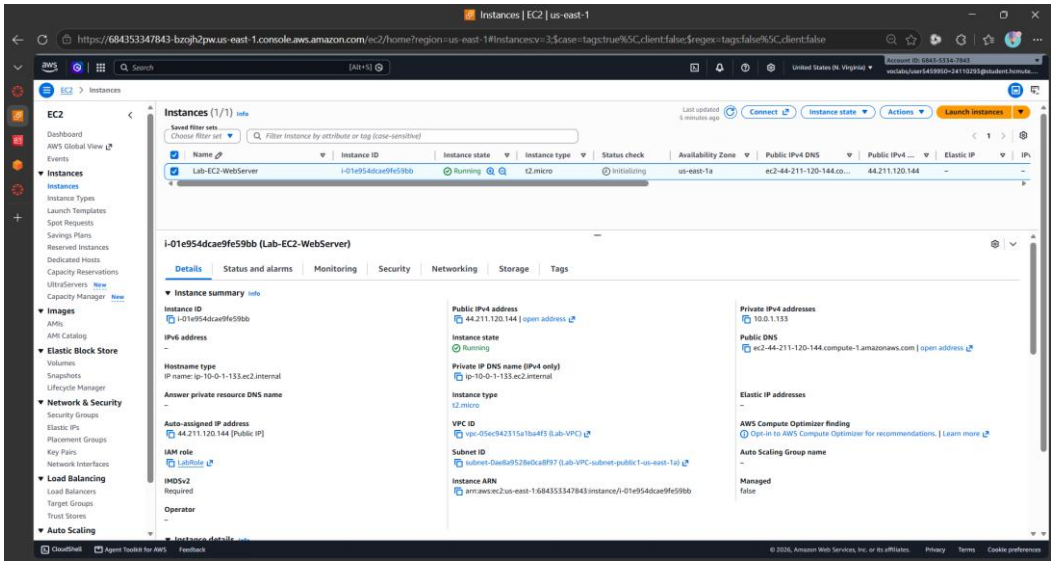
3. Cấu hình AWS Secrets Manager & KMS



Ảnh 3.1: Khởi tạo Secret lưu trữ thông tin xác thực cơ sở dữ liệu trên AWS Secrets Manager.

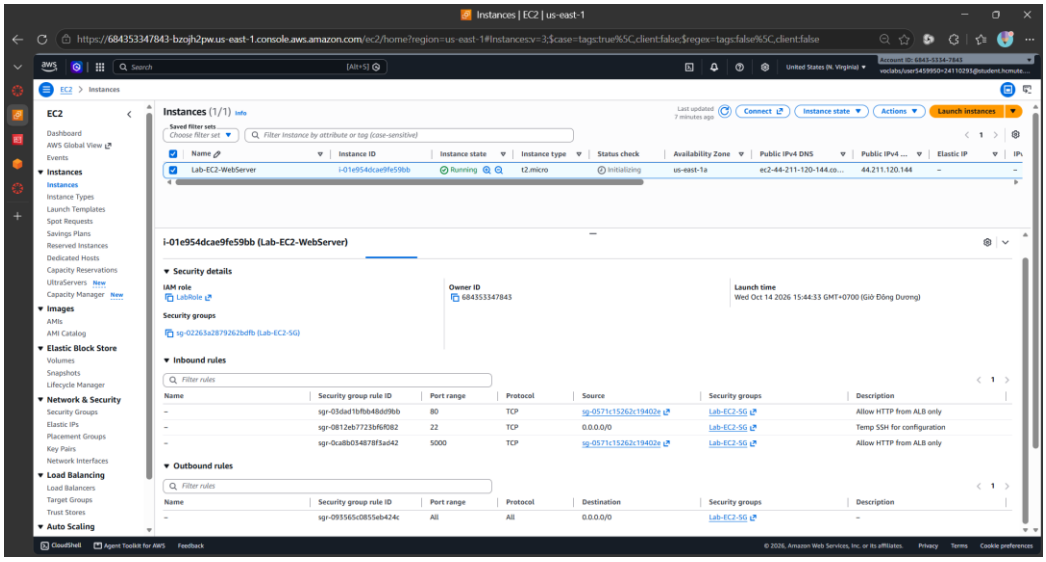
- Toàn bộ thông tin tài khoản quản trị adminapp và mật khẩu truy cập sec-app-db được đóng gói an toàn và mã hóa với AWS KMS.
- Triển khai theo chuẩn bảo mật không lưu mật khẩu tĩnh (Zero Hardcoded Secrets) trên máy chủ Web/App.

4. Dựng máy ảo EC2 Web Server & gán IAM Instance Profile



Ảnh 4.1: Thông tin cấu hình chi tiết máy ảo Web Server

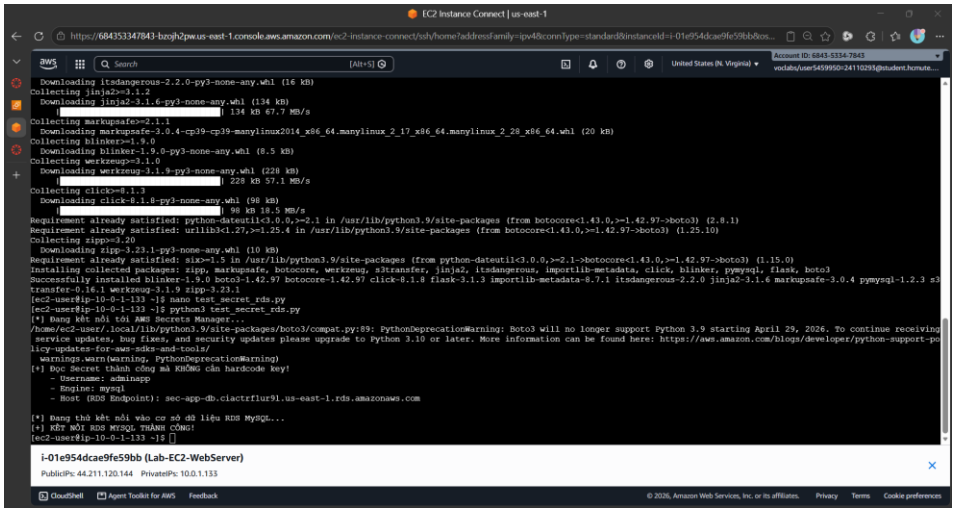
- Máy ảo được gắn vào Lab-VPC (vpc-05ec942315a1ba4f3), thuộc Subnet Lab-VPC-subnet-public1-us-east-1a.
- **IAM role:** Gán LabRole (qua LabInstanceProfile) nhằm cung cấp quyền hạn tự động tương tác với AWS Secrets Manager và KMS theo cơ chế AWS STS Token mà không cần cấu hình Access Key tĩnh trong mã nguồn.



Ảnh 4.2:Phân tầng an ninh Security Group của EC2

- **Cổng dịch vụ Web (HTTP 80 & Port 5000):** Áp dụng nguyên tắc (Least Privilege). Nguồn truy cập không mở ra toàn Internet (0.0.0.0/0), mà được trỏ cố định từ Lab-ALB-SG (sg-0571c15262c19402e). Ngăn chặn kẻ tấn công bypass Load Balancer để gửi request trực tiếp đến ứng dụng.
- **Cổng quản trị (SSH 22):** Được mở tạm thời từ Internet phục vụ cấu hình ban đầu và cài đặt thư viện phần mềm cho hệ điều hành.

5. Viết mã nguồn ứng dụng & kiểm thử kết nối động

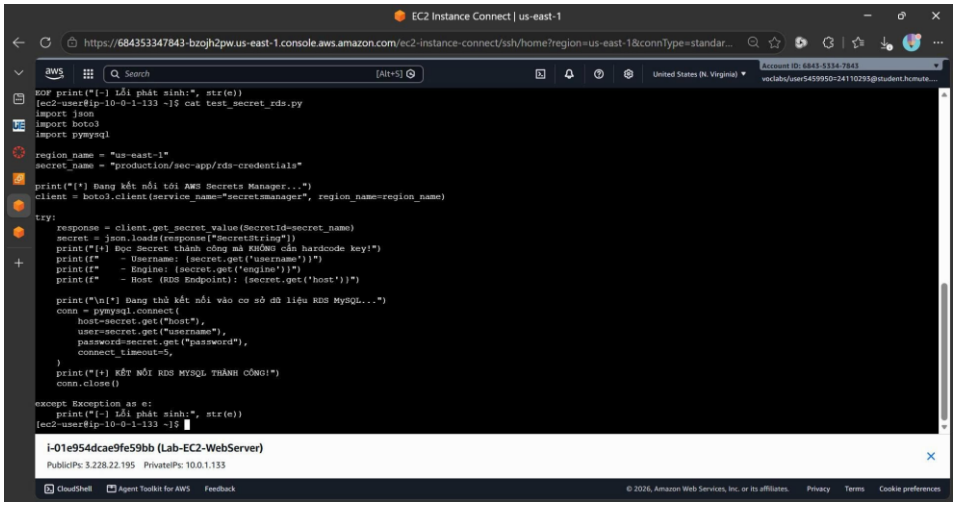


Ảnh 5.1: Minh chứng thực nghiệm nạp Secret & kết nối DB

- **Cơ chế thực thi:** Ứng dụng chạy trên máy chủ EC2 sử dụng thư viện AWS SDK (boto3) để truy vấn Secret production/sec-app/rds-credentials từ AWS Secrets Manager.
- **Đánh giá an ninh (Lớp 3 - Zero Hardcoded Credentials):**

- Mã nguồn không lưu bất kỳ thông tin đăng nhập nào dạng plain-text. Phiên truy cập của EC2 thông qua LabInstanceProfile được AWS xác thực ngầm và giải mã dữ liệu trả về an toàn.
- Máy ảo lấy được động các tham số: username (adminapp), engine (mysql), và địa chỉ host (sec-app-db...).

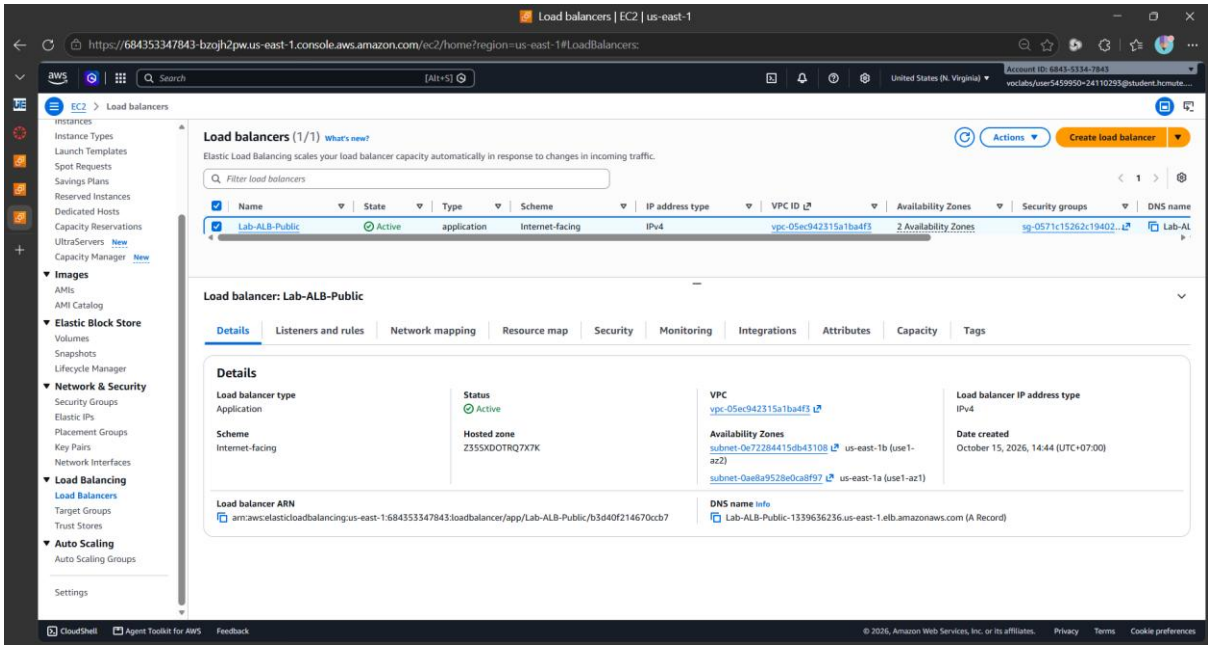
Kết quả kiểm thử kết nối: Ứng dụng mở thành công luồng TCP qua cổng 3306 tới máy chủ cơ sở dữ liệu sec-app-db thông qua Lab-RDS-SG, xác nhận thông tuyến nội bộ giữa tầng Web App và tầng Database.



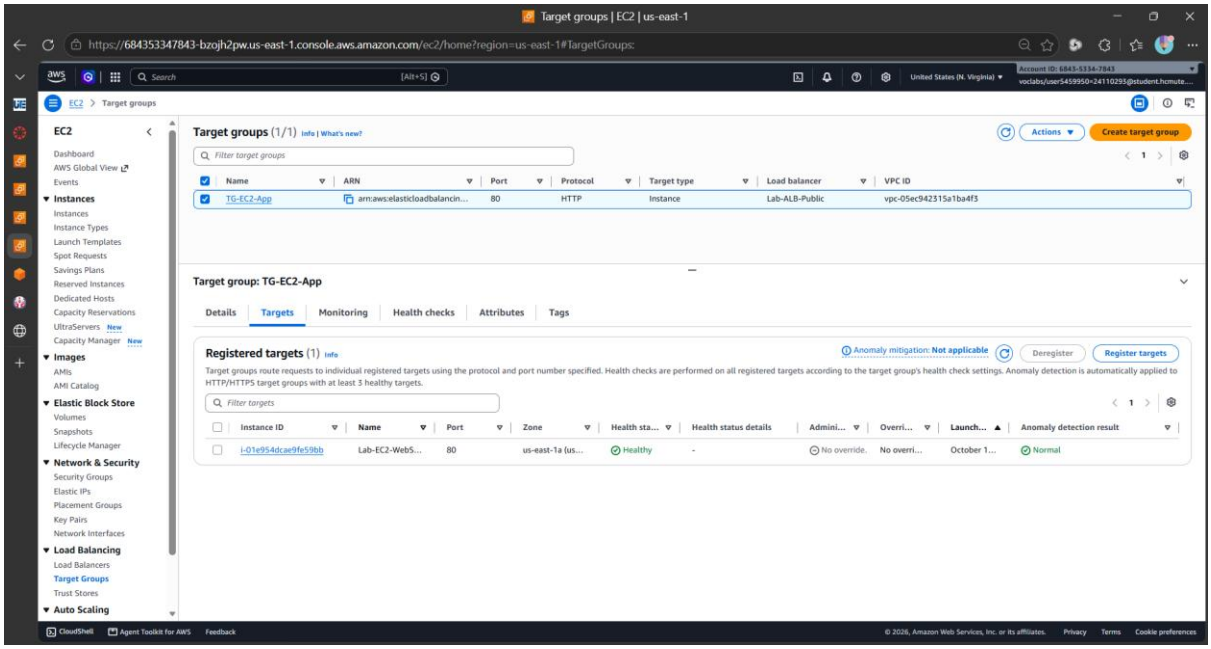
Ảnh 5.2: Mã nguồn kiểm thử kết nối (test_secret_rds.py) tuân thủ chuẩn an toàn thông tin Zero Hardcoded Secrets.

- Toàn bộ quá trình định danh và lấy mật khẩu truy cập database được ủy quyền cho dịch vụ AWS Secrets Manager thông qua IAM Instance Profile (LabRole).
- Mã nguồn tuyệt đối không lưu trữ tài khoản, mật khẩu hoặc AWS Access Key dạng văn bản rõ (plain-text), loại bỏ hoàn toàn nguy cơ rò rỉ thông tin đăng nhập khi chia sẻ mã nguồn hoặc bị tấn công đọc trộm file.

6. Cấu hình Target Group và Application Load Balancer



Ảnh 6.1: Cấu hình Application Load Balancer (Lab-ALB-Public) đa vùng sẵn sàng (Multi-AZ)



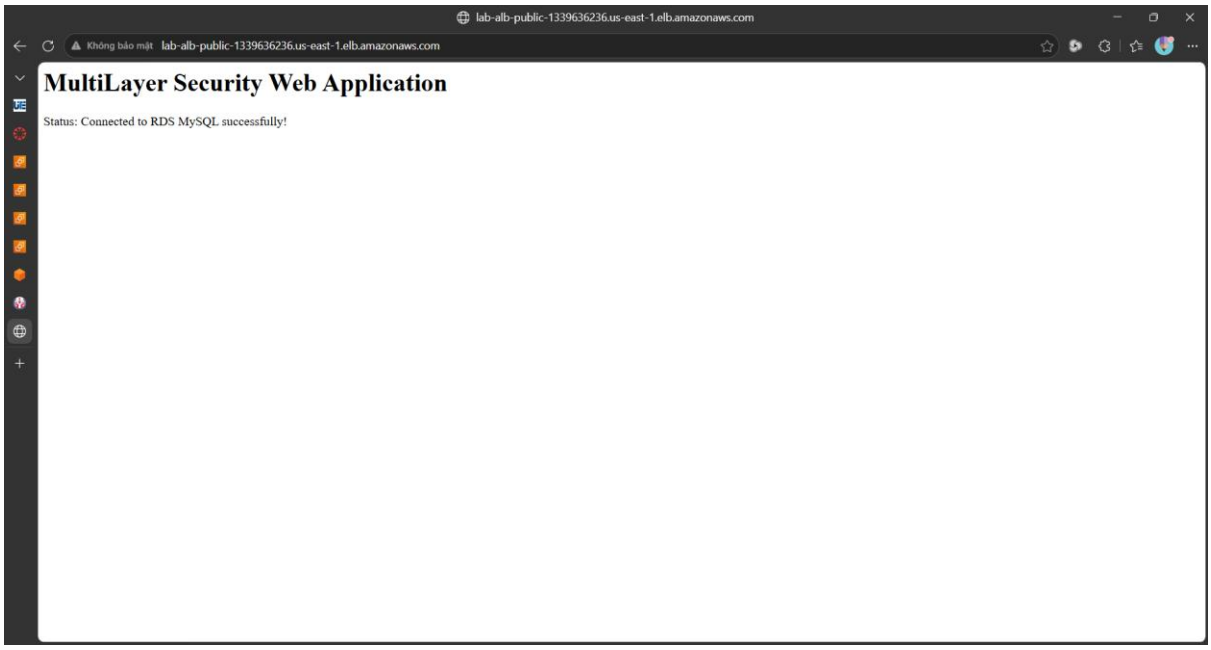
Ảnh 6.2: ánh xạ Target Group TG-EC2-App

- ALB được đặt tại 2 Public Subnet đóng vai trò Reverse Proxy tiếp nhận lưu lượng từ người dùng, ngăn cách hoàn toàn truy cập trực tiếp từ Internet vào máy chủ ứng dụng.

- Cơ chế Health Check kiểm tra định kỳ tình trạng sống của máy ảo trên port 80 và xác nhận trạng thái `Healthy`, đảm bảo tính sẵn sàng cao (High Availability).

III. Kiểm thử từng thành phần

1. Kiểm thử tích hợp hệ thống & Kiểm thử định tuyến bộ cân bằng tải



Ảnh 7.1: Kiểm thử tích hợp (Integration Testing) – Truy cập ứng dụng web thành công qua DNS Name của Application Load Balancer (Lab-ALB-Public)

- **Mục tiêu kiểm thử:** Xác thực luồng định tuyến lưu lượng từ người dùng bên ngoài Internet qua bộ cân bằng tải tới máy chủ ứng dụng và khả năng truy vấn cơ sở dữ liệu nội bộ.
- **Kết quả thực nghiệm:**
- Trình duyệt máy khách gửi request trực tiếp đến địa chỉ DNS công khai của ALB http://Lab-ALB-Public-1339636236.us-east-1.elb.amazonaws.com
- Giao diện web hiển thị tiêu đề MultiLayer Security Web Application cùng dòng trạng thái xác nhận: **Status: Connected to RDS MySQL successfully!**

Đánh giá kiến trúc phân tầng an ninh (Defense-in-Depth & Zero-Trust):

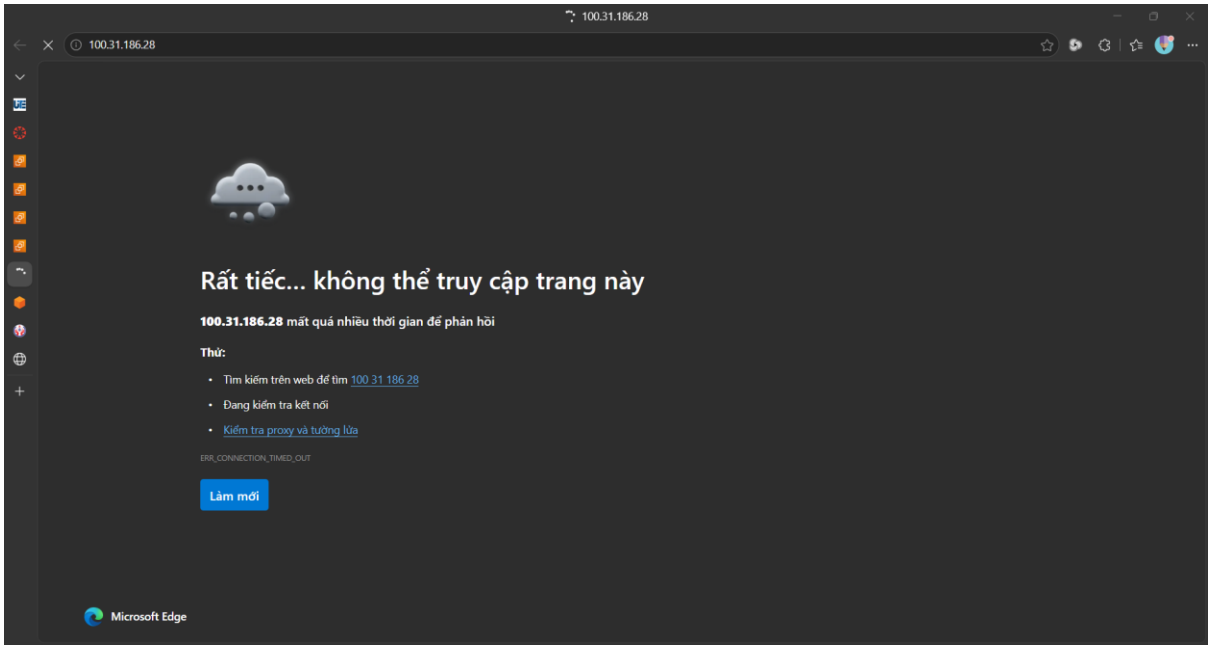
- **Tính toàn vẹn của chuỗi kết nối:** Minh chứng toàn bộ luồng dữ liệu 3 tầng (3-Tier) đã thông tuyến hoàn hảo:

  Client → ALB (Public Subnets)
  → EC2 Web Server $\xrightarrow[\text{IAM Role}]{\text{SDK}}$ Secrets Manager $\xrightarrow[\text{Port 3306}]{\text{Credentials}}$ RDS MySQL (Private Subnet)

- **Che giấu hạ tầng (Network Abstraction):** Địa chỉ IP thực của máy chủ EC2 và cụm cơ sở dữ liệu RDS hoàn toàn được che giấu sau ALB. Người dùng chỉ biết tới endpoint của Load Balancer, ngăn chặn việc tấn công trực diện vào máy chủ dịch vụ.

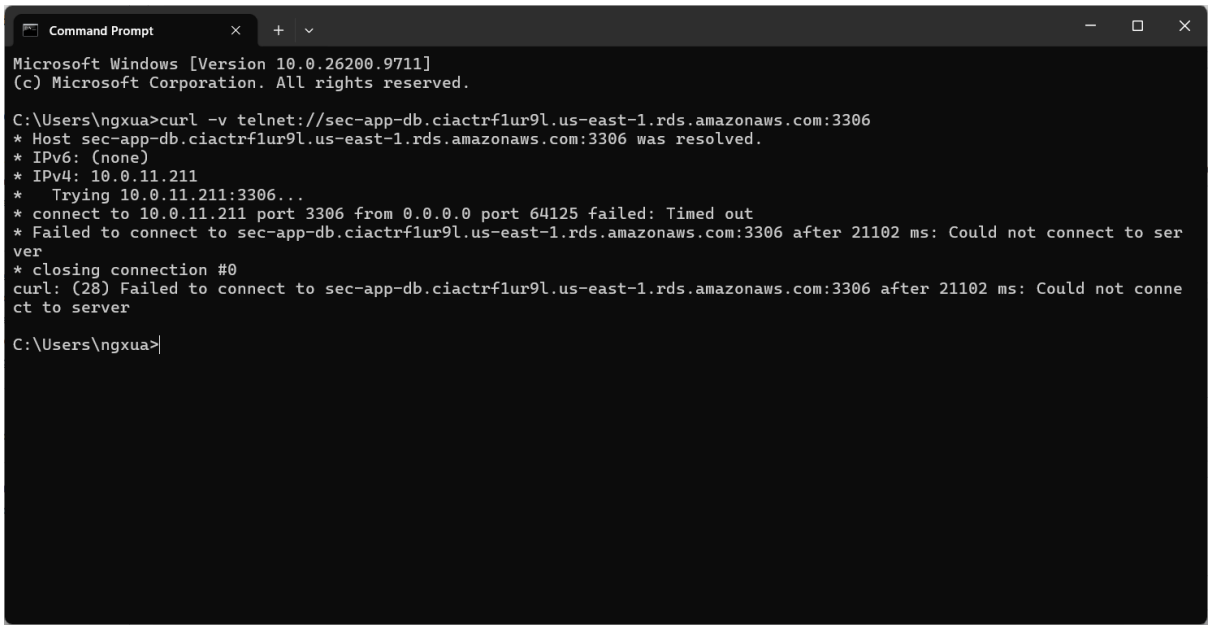
- **Xác thực tự động không lưu mật khẩu tĩnh:** Ứng dụng tự động lấy secret đăng nhập thành công từ AWS Secrets Manager qua quyền hạn của LabInstanceProfile để kết nối vào Database mà không cần ghi cứng mật khẩu trong code.

2. Kiểm thử an ninh độc lập



Ảnh 8.1: Kiểm thử cách ly máy chủ (EC2 Security Isolation) – Truy cập trực tiếp qua Public IP của EC2 bị chặn hoàn toàn.

- Do thực hiện chính sách tối ưu hóa chi phí (Stop instance khi không sử dụng), địa chỉ Public IPv4 của máy chủ EC2 là địa chỉ động (Dynamic IP) và được AWS tái cấp phát qua các phiên làm việc, trong khi định danh máy chủ (i-01e954dcae9fe59bb) và địa chỉ Private IP (10.0.1.133) được bảo toàn cố định
- Dù máy ảo có gắn IP công khai, Security Group Lab-EC2-SG chỉ cho phép lưu lượng Inbound cổng 80 bắt nguồn từ ID của Lab-ALB-SG.
- Request trực tiếp từ mạng Internet bên ngoài không khớp quy tắc bảo mật nên bị Firewall lớp ảo loại bỏ (Drop packet/Connection timed out), bảo vệ máy chủ ứng dụng trước các đợt scan cổng và tấn công trực diện từ không gian mạng.



Ảnh 8.2: Kiểm thử cách ly cơ sở dữ liệu (Database Security Isolation) – Kết nối từ Internet tới cổng 3306 của RDS Endpoint thất bại.

- Cơ sở dữ liệu được cấu hình Publicly Accessible = No và đặt trong lab-rds-subnet-group thuộc các Private DB Subnets không có route ra Internet Gateway.
- Quy tắc an ninh của Lab-RDS-SG thực thi cơ chế chuỗi (Chaining) nghiêm ngặt: Chỉ mở cổng TCP 3306 duy nhất cho Lab-EC2-SG. Mọi nỗ lực truy vấn trực tiếp từ ngoài môi trường đám mây đều bị ngăn chặn tuyệt đối.